

Quand la contagion n'est pas identifiable : borner le capital DORA plutôt que le poser

Quantification du besoin de capital lié à la non-conformité au règlement DORA

Kélian Kaddouri

ENSAE Paris, filière Actuariat · Nexialog Consulting

Mémoire présenté devant l'ENSAE Paris pour l'obtention du diplôme de la filière Actuariat et l'admission à l'Institut des actuaires

DORA impose une maîtrise, aucun dispositif n'en fait du capital



La Formule Standard charge le risque opérationnel au forfait, donc elle est aveugle à la conformité.

Un score qualitatif de conformité ne dit rien du capital qu'une direction des risques doit immobiliser.

À retenir Une exigence de maîtrise sans traduction prudentielle : c'est le vide que ce travail comble.

Une question en deux temps, et trois apports

Combien coûte en capital de ne pas se conformer à DORA, et jusqu'où ce chiffre peut-il être affirmé ?

Méthodologique

Une cascade dirigée
entre domaines de contrôle,
trois propriétés démontrées

Empirique

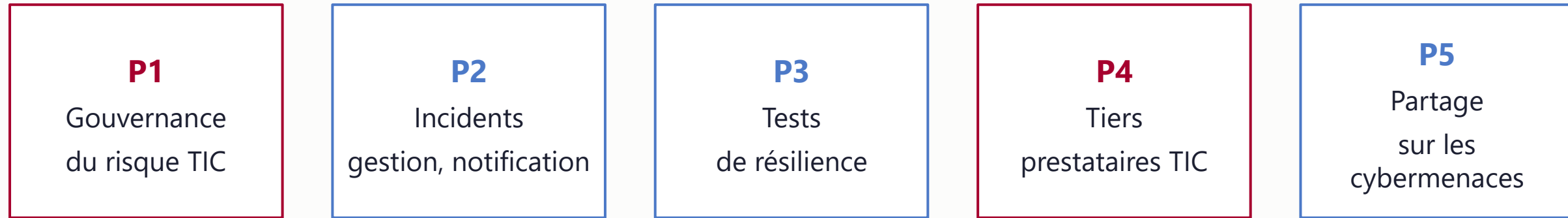
Une frontière
d'identifiabilité :
ce que la donnée ne dit pas

Opérationnelle

La donnée manquante
devient une exigence
de reporting

À retenir La seconde moitié de la question fait le travail : elle interdit de publier une précision que la donnée ne porte pas.

Cinq domaines de contrôle, pas cinq cases à cocher



La défaillance de l'un dégrade la capacité de l'entité à tenir les autres : une gouvernance défaillante retarde la détection, une dépendance non maîtrisée ouvre une porte que les tests n'ont pas explorée.

À retenir La non-conformité ne reste pas dans son pilier : elle se propage. En rouge, les deux piliers qui émettent le plus.

Source : mémoire, chapitres 1 et 2 ; matrice de propagation, chapitre 6.

La donnée montre la co-occurrence, jamais la direction

Observable

Fréquence des incidents
Sévérité des pertes
Co-occurrence entre piliers
Structure par vecteur d'attaque

Non identifiable

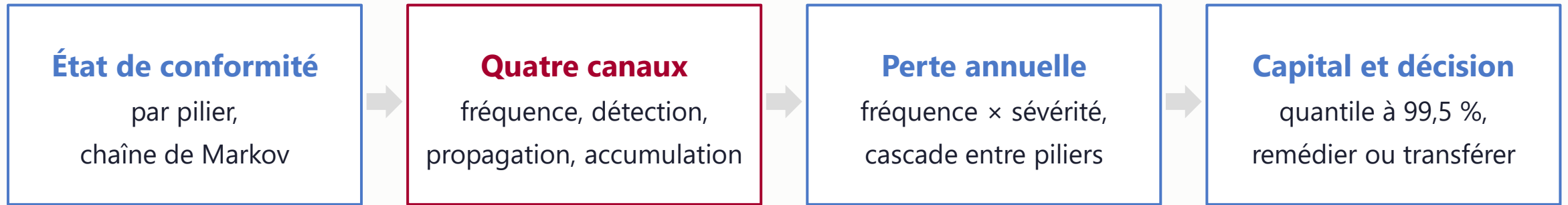
La DIRECTION de la contagion
Quel pilier entraîne l'autre
Une matrice et sa transposée
sont indistinguables

Sept sources, chacune avec son statut de preuve déclaré, de la base versionnée et rejouable à la citation externe non recalculable.

À retenir Cette limite n'est pas un défaut du dispositif de données : elle est structurelle, et elle commande la suite.

Source : mémoire, chapitre 4 (sources et statuts de preuve) et chapitre 8.

D'un état de conformité à une décision, en quatre étapes



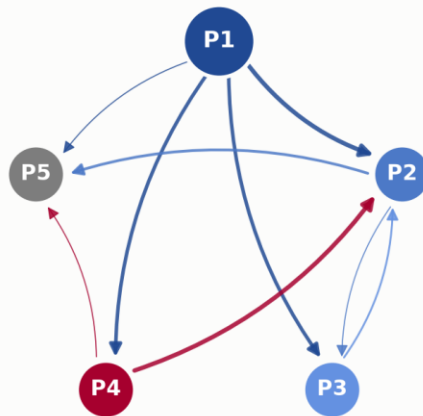
Deux canaux sont calibrables sur données, la fréquence et la détection. Deux sont des bornes posées, la propagation et l'accumulation tiers.

À retenir Le modèle est partiellement calibré et partiellement borné, et le document dit lequel est lequel.

L'ordre de propagation change la criticité, une copule ne le voit pas

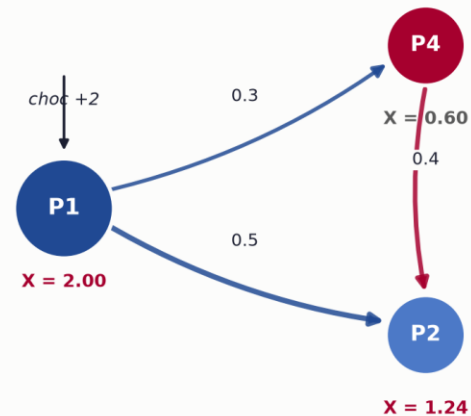
La propagation dirigée W : qui entraîne qui, et de combien

(A) Le réseau dirige W (structure de TRANS)



flèche $i \rightarrow j$ = i entraîne j ; épaisseur $\propto$ force. P1 émet fort, reçoit peu $\rightarrow$ asymétrie.

(B) Cascade d'un choc +2 sur P1 (exemple chiffre)



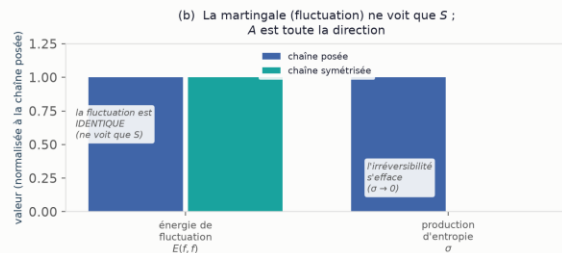
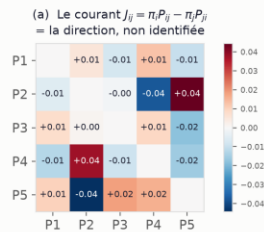
seuil $K = 1 \rightarrow$ P1 et P2 déclenchent, pas P4.
Même choc place sur P2 $\rightarrow$ reste local (1 seul incident).

À retenir Une copule capture la co-occurrence des pertes, mais symétriquement : elle ne distingue pas ce qui entraîne de ce qui subit.

Source : mémoire, chapitre 6 ; figure produite par le script 29 ; comparaison au jumeau copule, chapitre 10.

La direction n'est pas identifiable, et c'est un résultat

Z11 : la direction A est le courant irréversible d'un processus, ce que la martingalisation retire et que la co-occurrence ne voit pas



(c) Renversement du temps :
 S invariante, A change de signe

temps $t \rightarrow$
 $\leftarrow t$ renversé

$$P = S + A$$
$$\tilde{P} = S - A$$

S : co-occurrence, A : direction
(chaîne renversée : A change de signe)
 S : identifiée, A : placebo $z = -0.33$, compatible avec $\sigma = 0$ (réversible).

La matrice se décompose en une partie symétrique et une partie antisymétrique.

La donnée identifie la première, la co-occurrence.

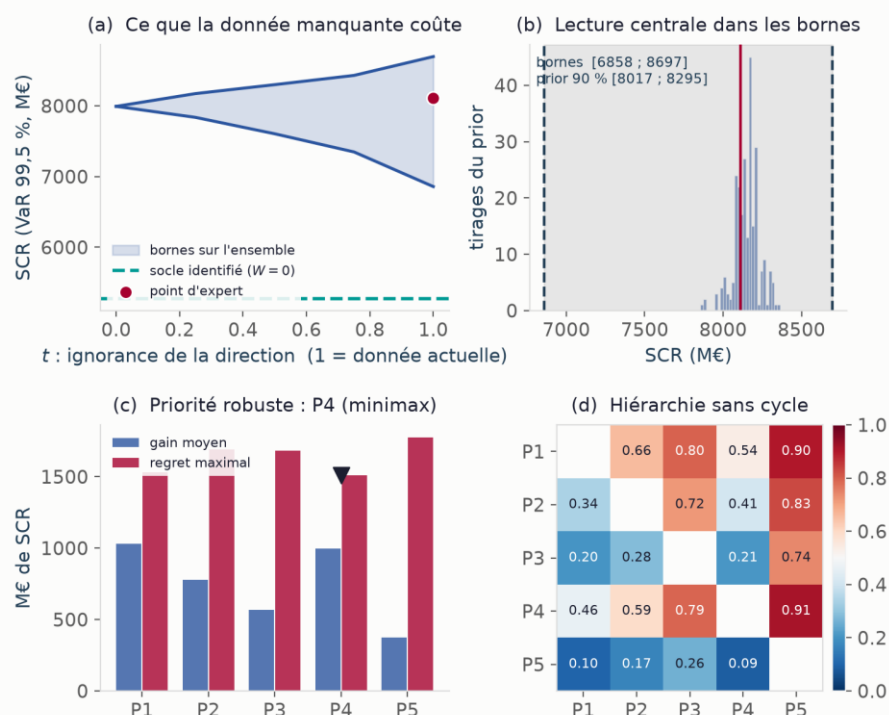
Elle n'identifie pas la seconde, la direction.

Une matrice et sa transposée sont indistinguables pour la donnée, et donnent pourtant un capital et une décision différents.

À retenir Ce n'est pas un échec du modèle : c'est ce qui interdit de publier une direction comme si elle avait été observée.

Du point à la bande : borner plutôt que poser

Z : identification partielle de la contagion dirigée, et bornes de capital



Plutôt que de poser la direction, le capital est borné sur l'ensemble des matrices admissibles.

1 024 sommets, énumérés exhaustivement

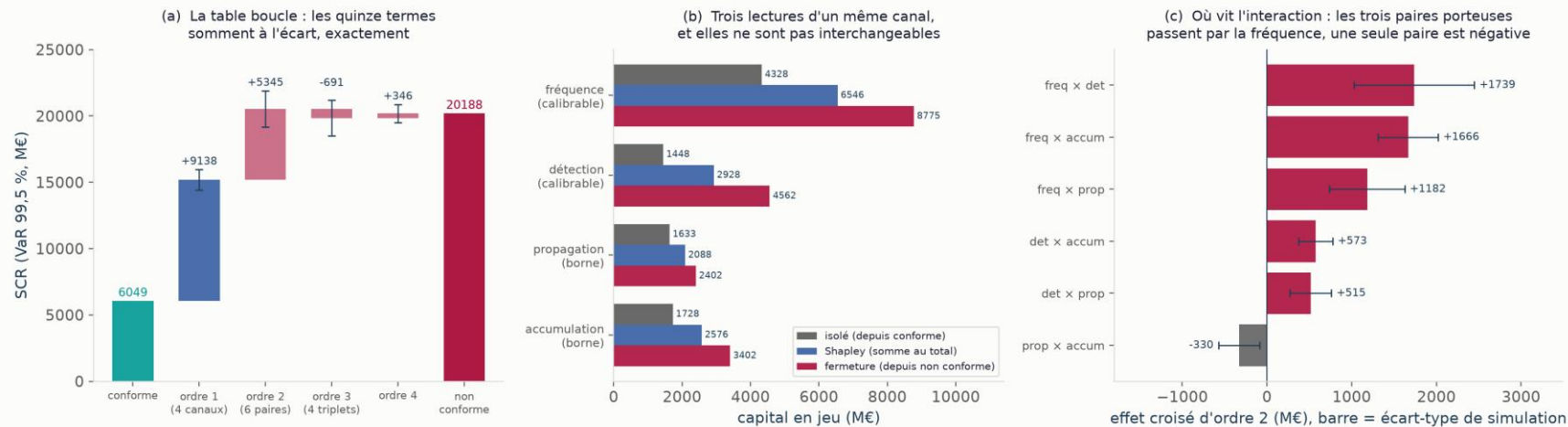
L'ignorance directionnelle se paye linéairement, et son coût maximal est connu d'avance : c'est plus favorable qu'un intervalle de confiance ordinaire.

Le principe affiché reste illustratif

À retenir La bande est le résultat rigoureux : elle quantifie une incertitude structurelle au lieu de la masquer.

Quatre canaux déplacés, et leurs effets ne s'additionnent pas

S24 : la table complète des quatre canaux, et où vivent les 5 001 M€ d'interaction



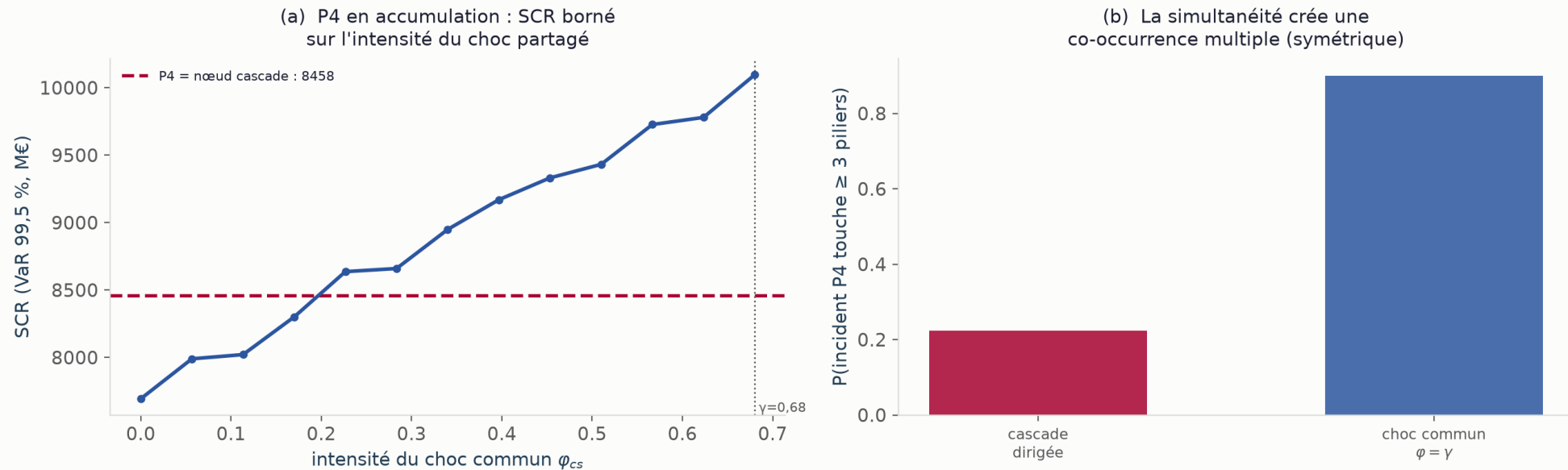
Au secteur : besoin de capital de 6 049 à 20 188 M€, facteur 3,34. La non-conformité n'ajoute aucune pénalité, elle déplace quatre paramètres de la loi de perte.

Canaux isolés 9 138 M€ Écart total 14 139 M€ Interaction 5 001 M€, soit 35 %

À retenir Remédier un canal rapporte davantage à une entité défaillante partout : c'est la colonne de fermeture qu'un plan doit citer.

Le pilier des tiers concentre, il ne propage pas seulement

Z9 : le pilier tiers comme nœud d'accumulation, dans la partie identifiée



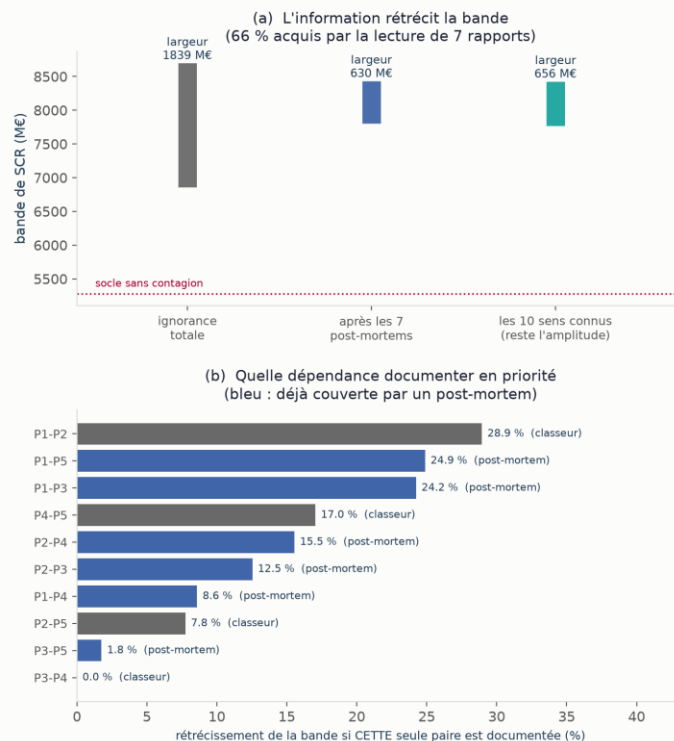
Un prestataire commun crée un choc partagé entre entités : ce n'est plus de la contagion, c'est de

À retenir C'est exactement ce que DORA demande de cartographier : la dépendance à des prestataires TIC critiques.

Source : mémoire, annexe C (adaptations par pilier) ; script 22.

La donnée manquante devient une exigence de reporting

Z18 : la valeur de l'information manquante, chiffrée et hiérarchisée : quelle dépendance le registre DORA devrait documenter d'abord



Quatre champs de registre, hiérarchisés par ce qu'ils resserrent :

- **horodatage des incidents**
- **domaine de contrôle touché**
- **cause commune consolidée**
- **champs renseignés obligatoires**

À retenir Le registre d'incidents devient un instrument de capital : chaque champ renseigné resserre la bande.

Source : mémoire, chapitre 12 ; script 55.

Trois décisions, et une confusion à ne pas commettre

Remédier

Prioriser les canaux
calibrables :
fréquence et détection

Détenir

Le capital immobilisé
coûte chaque année,
pas une seule fois

Transférer

Comparer au prix
de marché du même
risque

Une borne de capital n'est pas un budget de remédiation : deux des quatre canaux sont des bornes posées, et leur part n'est pas une enveloppe à dépenser.

À retenir Le bénéfice d'une remédiation a deux composantes, et la plus grosse n'est pas le capital libéré mais la perte évitée.

Ce que ce travail n'établit pas, et ce qui tient malgré cela

Non établi

Direction de contagion non identifiée
Niveau absolu illustratif,
borne supérieure à l'entité
Incertitude de queue large
Deux canaux bornés, non calibrés

Établi malgré cela

Le signe et l'ordre de l'écart
La hiérarchie des piliers
Le cadre de bornage et son coût
La recommandation de reporting
La priorité de collecte de données

À retenir Ces limites sont publiées, pas concédées : une thèse de départ a été réfutée par son auteur et un chiffre requalifié en borne.

Trois messages

1. La non-conformité à DORA se traduit en coût de risque et en capital, par le déplacement de quatre paramètres de la loi de perte.
2. La dépendance directionnelle ne doit pas être calibrée sur des données qui ne l'identifient pas.
3. La limite de données devient une recommandation actionnable pour l'entité et pour le régulateur.

Quand la dépendance n'est pas identifiable, la bonne réponse actuarielle n'est pas la fausse précision : c'est une borne, une hiérarchie de données et une décision mieux informée.

Questions

Conformité

Quatre canaux

Perte annuelle

Capital borné

Annexes

Sept sources, et chacune avec son statut de preuve

Sévérité en euros : base internationale de pertes opérationnelles

Chronologie de brèches : fréquence et étude d'événement

Corpus de rapports post-mortem : structure de la direction

États réglementaires publiés : quatre bilans réels, anonymisés

Comptage d'incidents par vecteur : structure, jamais niveau

Étude de marché cyberassurance : contexte, aucune calibration

Deux statuts distingués : versionné et rejouable, ou citation externe non recalculable

Les paramètres, et ce qui est estimé, posé ou gelé

Sévérité : loi de Pareto généralisée au-delà du seuil, indice de queue 0,5954

Seuil 20,03 M€, 91 excès, calibration gelée depuis le 7 août 2026

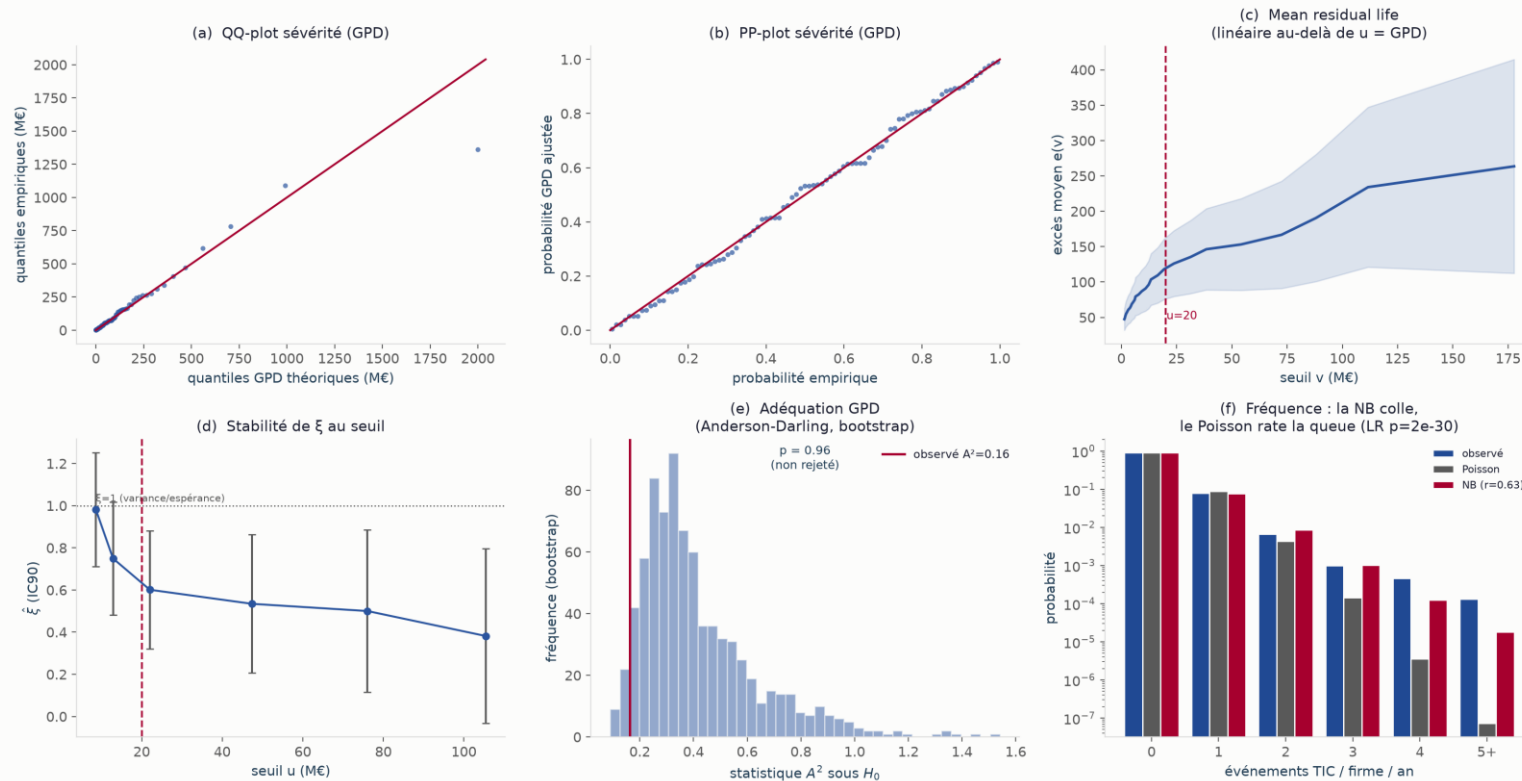
Fréquence : binomiale négative, validée hors échantillon

Gain de propagation : trois valeurs POSÉES, 0,45 / 0,68 / 0,90

Le capital est croissant en ce gain : l'ordre suffit, l'amplitude est un scénario

Pourquoi une loi de valeurs extrêmes pour la sévérité

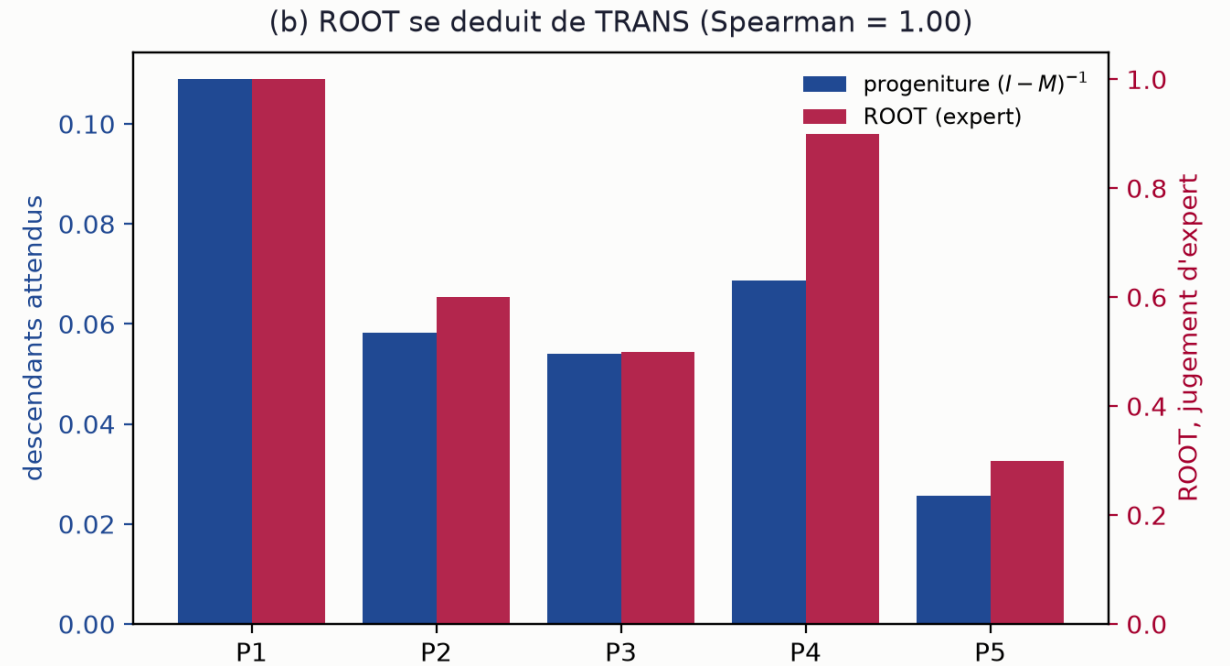
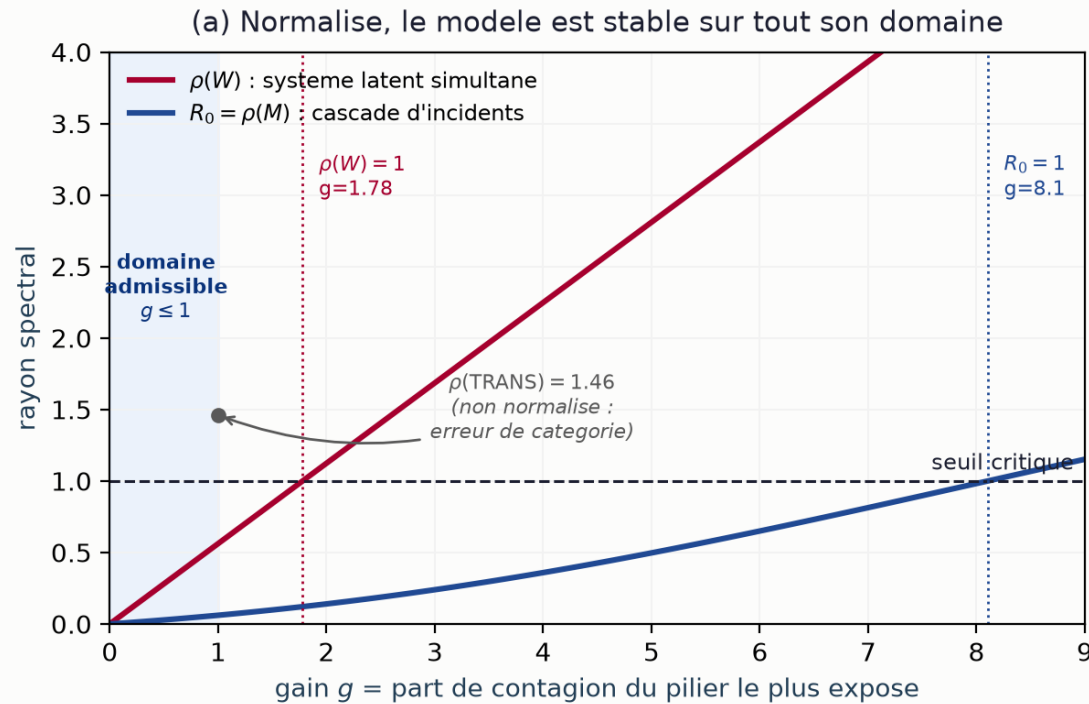
J3 : validation et adéquation du socle : la sévérité GPD et la fréquence NB passent les tests



Source : mémoire, chapitre 5 ; scripts 07 et 47.

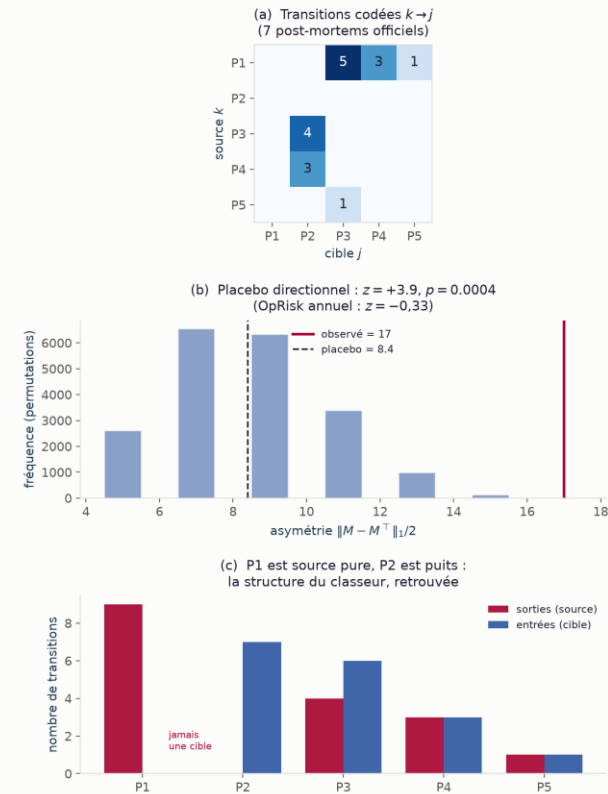
La cascade est un processus de branchement sous-critique

K3 : la cascade est un processus de branchement



Ce que le corpus documentaire corrobore, et ce qu'il ne lève pas

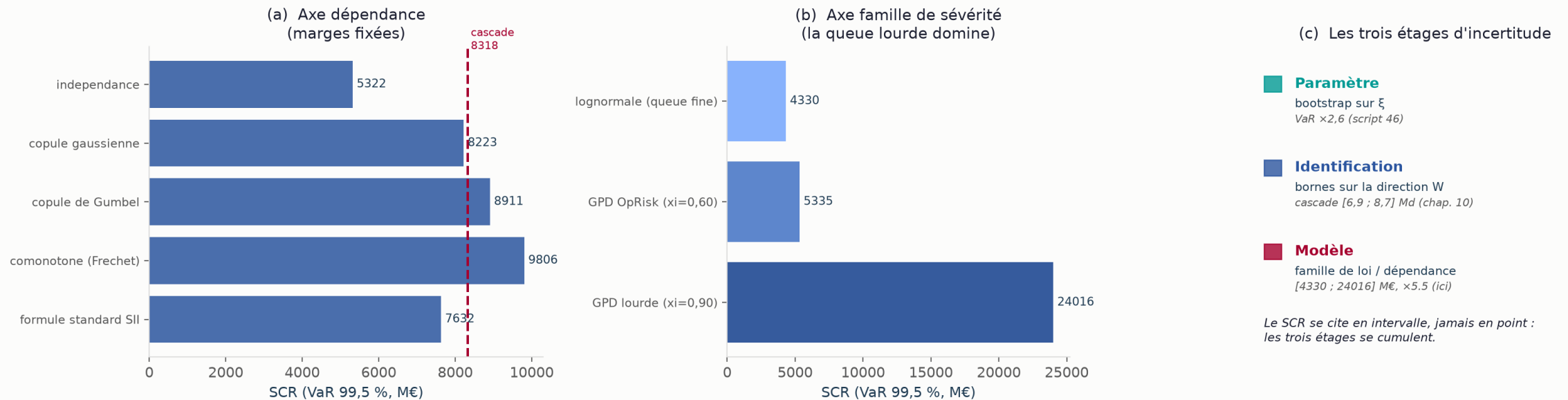
Z17 : la direction de W identifiée par codage de post-mortems officiels, là où les bases agrégées échouaient



Source : mémoire, chapitre 8 ; scripts 53, 59 et 64.

La bande de capital et ses trois étages d'incertitude

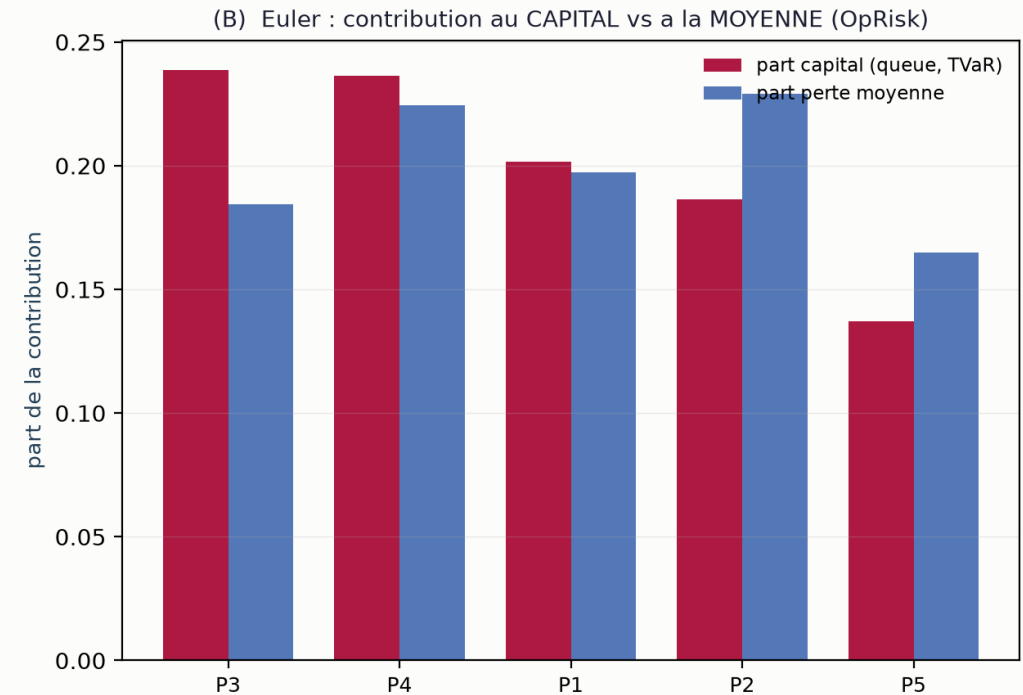
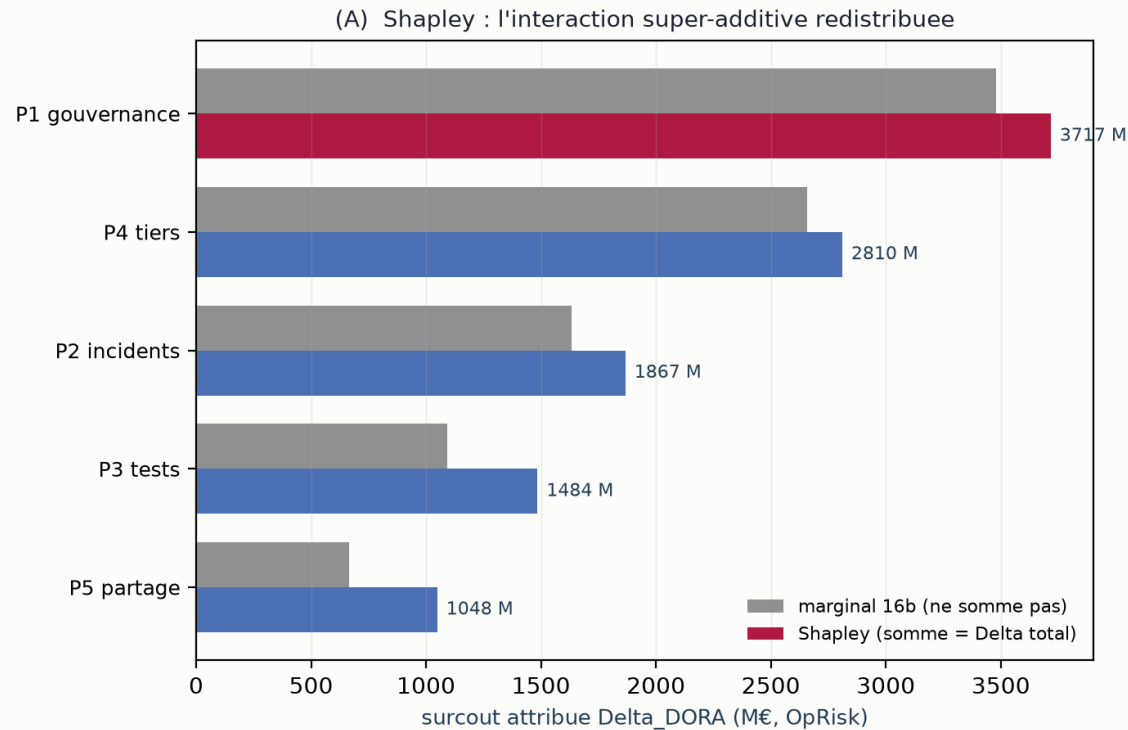
J4 : la bande de modèle, troisième étage d'incertitude ; le niveau bouge selon la famille, l'ordre d'amorce ne bouge pas



Source : mémoire, chapitre 11 ; script 48.

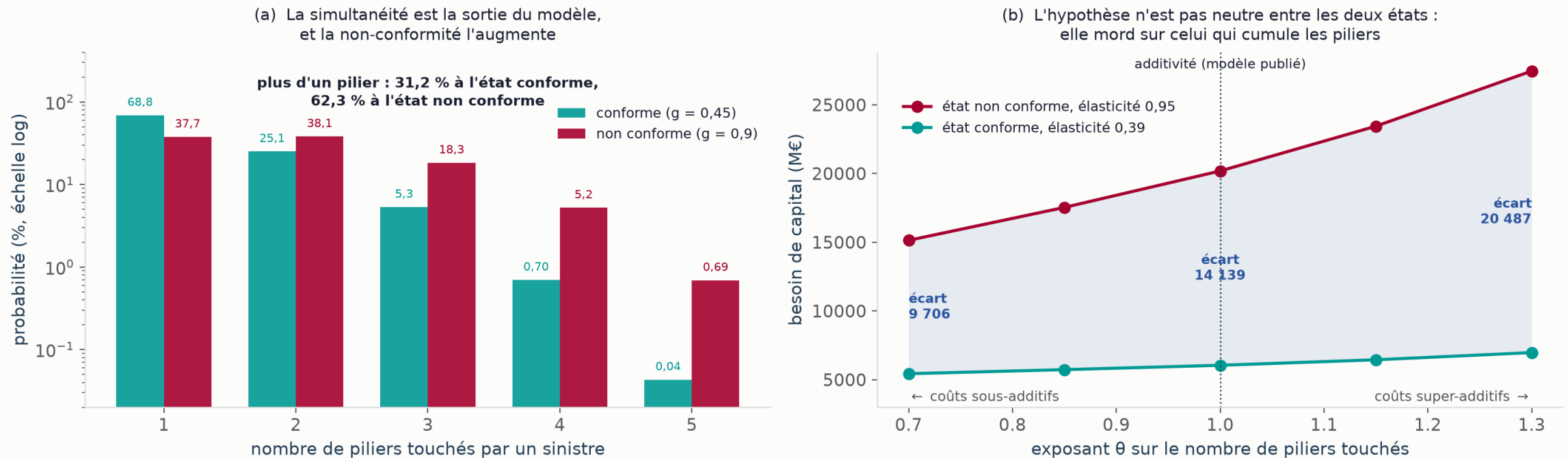
L'attribution par canal : trois lectures, non interchangeables

Allocation du capital DORA aux piliers : Shapley (surcout) et Euler (niveau)



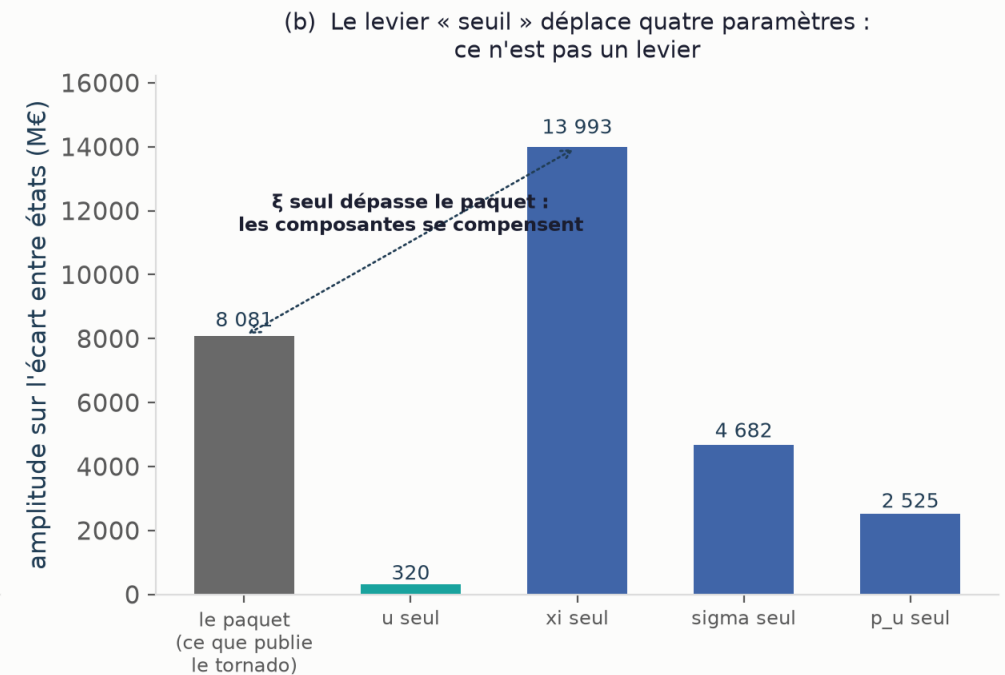
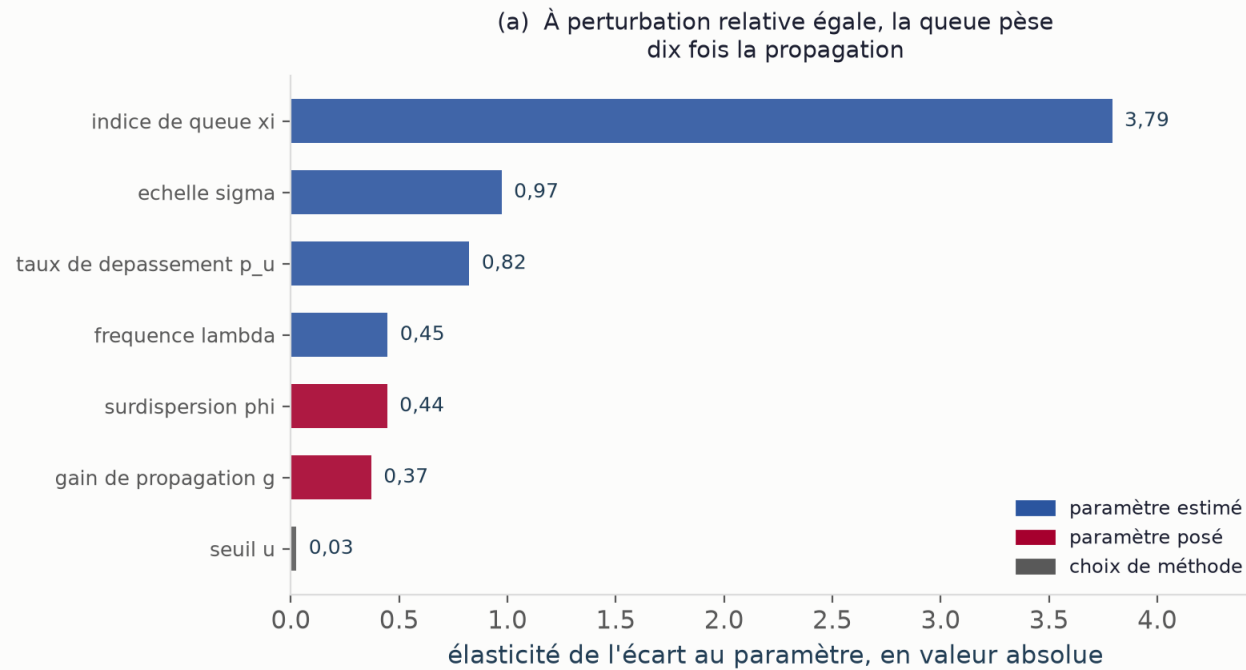
Défaillances simultanées : une sortie du modèle, pas une lacune

S30 : les défaillances simultanées sont la sortie du modèle, et l'additivité de leurs coûts est son hypothèse non testée la plus lourde



Les hypothèses, par ordre de ce qu'elles coûtent

S32 : le tornado renormalisé, et ce que l'ancien classement devait à ses pages



Glossaire

DORA : règlement européen sur la résilience opérationnelle numérique

SCR : capital de solvabilité requis sous Solvabilité II

VaR : quantile de la charge annuelle agrégée, ici à 99,5 %

Quantile de sévérité : quantile d'un sinistre isolé, ce n'est pas un capital

GPD : loi de Pareto généralisée, pour les excès au-delà d'un seuil

Copule : structure de dépendance symétrique, sans direction

Shapley : convention d'attribution d'un effet total entre leviers

Cascade : propagation dirigée entre domaines de contrôle